

Quarterly Code Security & Quality Audit

STATIC CODE ANALYSIS AND SECURITY AUDIT

Target Repository: vsg-payment-gateway-core Branch: release/v2.8.1 Scan Date: August 20, 2026 Analyzed By: Automated Pipeline (SonarQube) & Security Engineering Team

Executive Summary: The quarterly static application security testing (SAST) was performed on the core payment gateway repository. The analysis covered 145,000 lines of Java and Go code. The overall technical debt ratio remains acceptable at 4.2%, but security vulnerabilities require immediate attention before the Q4 code freeze.

Key Findings: - 2 Critical Vulnerabilities: Both relate to hardcoded cryptographic keys discovered in the legacy `EncryptionUtils.java` module. - 5 High Vulnerabilities: Primarily unvalidated input flows in the `/v1/process` REST endpoint, making the application susceptible to SQL injection attacks. - Code Smells: 412 instances of deprecated API usage and duplicated code blocks, contributing to roughly 14 days of technical debt. - Test Coverage: Unit test coverage has dropped to 76.5%, falling below our mandatory 80% threshold.

Remediation Plan: The Critical vulnerabilities must be patched immediately. The hardcoded keys must be extracted and migrated to our HashiCorp Vault implementation. The pipeline is currently configured to fail the build if test coverage remains below 80%; the QA team must introduce mock testing for the new asynchronous refund module by Friday.

A follow-up manual code review is scheduled for August 25 to verify the remediation of the High-severity SQLi vectors.